LABORATUVAR 2 · TIRSAN TREYLER · Otomatik Şasi Kaynak HücresiSafety Architecture

# IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad: Mahmut DAĞAŞAN

Tarih:10.29.2026

**Kavram: Zone** = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

## Görev A — varlıkları bölgelere ayırın

### Varlık listesi

Üretim PLC, Emniyet PLC'si, HMI, robot sürücüleri, kaynak makinesi güç kaynağı, internete açık uzak bakım modülü, bulut telemetri, Wi-Fi AP (parolası kartonda), 2 kilitsiz USB, "admin/admin" servis hesabı.

**1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**

- **Saha / Kontrol Bölgesi (Zone 1 - OT Cell Zone):**
  - *Varlıklar:* Üretim PLC, Emniyet PLC'si, HMI, Robot Sürücüleri, Kaynak Makinesi Güç Kaynağı.
  - *Gerekçe:* Makinenin kaynak ve emniyet işlevlerini doğrudan yürüten, fiziksel sürece bağlı kritik cihazlardır.
- **Dış Erişim / Kurumsal Ağ Bölgesi (Zone 2 - DMZ / Remote Access Zone):**
  - *Varlıklar:* İnternete açık uzak bakım modülü, Bulut telemetri, Wi-Fi AP.
  - *Gerekçe:* Dış dünya (internet/bulut) ile doğrudan haberleşen, güvenlik riski daha yüksek olan arayüz bileşenleridir.
- **Güvensiz Varlıklar / Tehdit Unsurları:**
  - *Varlıklar:* 2 kilitsiz USB, "admin/admin" servis hesabı.
  - *Gerekçe:* Doğrudan bir bölgeye dahil edilmemeli, sertleştirmeyle (hardening) kaldırılmalı veya denetlenmelidir.

**2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?**

- **Cevap:** Dış Erişim / DMZ bölgesine düşer. Bu haliyle OT Saha Bölgesi (Zone 1) içinde **KALAMAZ**.
- **Neden:** Doğrudan internete açık olması, zayıf/varsayılan kimlik doğrulama veya doğrudan bağlantı izni barındırması durumunda tüm kaynak hücresine (Zone 1) siber saldırı kapısı aralar. Güvenli hale getirilip DMZ alanına çekilmeli, endüstriyel firewall arkasına alınmalıdır.

**3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?**

- **Conduit 1 (İnternet/DMZ $\leftrightarrow$ Zone 1 OT Ağ Geçişi):** Dış ağdan gelen uzak bakım modülü ile Safety PLC / Üretim PLC arasındaki hat.
  - *Kontrol:* Güvenlik Duvarı (Firewall) kuralları, Deep Packet Inspection (DPI) ve endüstriyel protokol kısıtlamaları (sadece yetkili portlar).
- **Conduit 2 (Fiziksel / Kablosuz Uç Noktalar $\leftrightarrow$ Zone 1 OT Ağ Geçişi):** Wi-Fi AP, kilitsiz USB portları ve servis hesapları geçişi.
  - *Kontrol:* Port bazlı kimlik doğrulama (802.1X), USB medya taraması/engellemesi ve merkezi yetkilendirme.

## Görev B — uzak erişim kararı (6 satır)

| Karar | Seçenekler | Seçiminiz + nedeni |
|---|---|---|
| **Aracı?** | Doğrudan / Jump server | **Jump server:** Doğrudan OT ağına ve PLC'lere erişim ciddi güvenlik riskidir; oturum izolasyonu şarttır. |
| **Tünel?** | Açık / VPN | **VPN:** İnternet üzerinden yapılan tüm uzak erişimler şifreli bir tünel (IPsec/SSL VPN) üzerinden gerçekleştirilmelidir. |
| **Kimlik?** | Parola / MFA | **MFA:** Yalnızca parola yeterli değildir; SMS/TOTP gibi çok faktörlü doğrulama şarttır. |
| **Hesap?** | Paylaşılan / Kişisel | **Kişisel:** "admin/admin" gibi ortak/paylaşılan hesaplar yerine kimin işlem yaptığını izleyebilmek için kişiye özel hesaplar kullanılmalıdır. |
| **Kayıt?** | Yok / Tam oturum kaydı | **Tam oturum kaydı:** Uzaktan yapılan tüm işlemler olası bir olay müdahalesi ve güvenlik denetimi için kayıt altına alınmalıdır. |
| **Zamanlama?** | Sürekli açık / Varsayılan kapalı | **Varsayılan kapalı:** Uzak erişim sürekli açık bırakılmamalı; yalnızca bakım gerektiğinde yetki verilerek açılmalıdır. |

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.